TECNOMARKET / GV.PO – Política Organizacional de Respuesta a Incidentes de Ciberseguridad

1. PROPÓSITO

La presente Política de Respuesta a Incidentes tiene como propósito **establecer el marco oficial** mediante el cual TECNOMARKET identifica, gestiona, comunica y recupera ante incidentes de seguridad de la información.
Esta política busca:

- **Reducir el impacto operativo** provocado por incidentes de seguridad.
- **Asegurar una respuesta rápida, estructurada y coordinada.**
- **Definir roles y responsabilidades claras** durante una situación de crisis.
- **Preservar la confidencialidad, integridad, disponibilidad y trazabilidad** de la información crítica de la empresa.
- **Promover la mejora continua** del programa de ciberseguridad mediante lecciones aprendidas, retroalimentación y ajustes al plan de respuesta.

La política aplica a **todo el personal, contratistas, proveedores y sistemas** que formen parte del ecosistema tecnológico de TECNOMARKET. Asimismo, establece los lineamientos esenciales para activar el proceso de respuesta a incidentes y garantizar una gestión responsable conforme a las regulaciones aplicables en México.

2. ALCANCE

Esta política es **aplicable y apelable** para:

- **Empleados**
- **Contratistas**
- **Proveedores que accedan a sistemas internos**
- **Infraestructura física**

- **Sistemas internos y servicios en la nube**
- **Datos corporativos**
- **Dispositivos corporativos y BYOD autorizados**

El alcance abarca todos los activos tecnológicos pertenecientes a TECNOMARKET, incluyendo computadoras, dispositivos móviles, IoT, servidores, redes, infraestructura on-premise y servicios alojados en la nube. Esta política se articula directamente con el documento **"RESPUESTA A INCIDENTES"**, así como con el **LISTADO DE ACTIVOS TECH**.

3. DEFINICIÓN DE INCIDENTES DE CIBERSEGURIDAD

Se considera "incidente" cualquier evento —intencional o accidental— que represente una amenaza para:

- los activos tecnológicos,
- los datos de la empresa,
- la continuidad operativa,
- la reputación de la organización,
- o la integridad de empleados y clientes.

Un incidente de seguridad puede incluir, pero no se limita a:

3.1. Amenazas técnicas

- Malware
- Ransomware
- Phishing / Spear phishing
- Exfiltración de datos
- Acceso no autorizado
- Robo de credenciales
- Intrusión en red
- Uso indebido de privilegios

- Vulnerabilidades explotadas
- Ataques internos (insider threats)
- Manipulación de registros
- Alteración de sistemas críticos

3.2. Ataques a aplicaciones

- Inyección SQL
- Cross-Site Scripting (XSS)
- Secuestro de sesión
- Man-in-the-Middle (MitM)
- Spoofing
- Fuerza bruta / diccionario

3.3. Infraestructura y servicios

- DoS / DDoS
- Compromiso de servicios en la nube
- Ataque a la cadena de suministro
- Compromiso de dispositivos móviles
- Compromiso de IoT
- Interrupción de servicios críticos

3.4. Amenazas físicas

- Robo de dispositivos
- Destrucción de hardware
- Sabotaje interno
- Espionaje corporativo

---

4. Relación con otros documentos

Esta política coordina, habilita y regula la aplicación del documento:

“RESPUESTA A INCIDENTES – TECNOMARKET”

Y mantiene conexión formal con:

- Política de Seguridad de la Información
- Código Ético de Privacidad y Seguridad
- Procedimientos de Gestión de Vulnerabilidades
- Política de Continuidad de Negocio (BCP)
- Política de Control de Acceso
- Procedimientos de Gestión de Registros y Evidencia

4. AUTORIDAD

La presente Política de Respuesta a Incidentes ha sido revisada, validada y aprobada por el **Authorizing Official (AO) / Risk Executive** de TECNOMARKET, quien tiene la responsabilidad final de supervisar el cumplimiento normativo, la gestión de riesgos y la autorización de políticas organizacionales.
El AO se reconoce como la autoridad encargada de firmar, actualizar y hacer cumplir esta política, asegurando que su aplicación se mantenga alineada con las obligaciones legales, los estándares de ciberseguridad y las necesidades del negocio

5. RESPONSABILIDADES

AO – Autoridad de Aprobación (Authorizing Official / Risk Executive)

- Aprueba formalmente la Política de Respuesta a Incidentes y sus actualizaciones.
- Supervisa que el programa de respuesta se alinee con los objetivos corporativos, la legislación aplicable y el apetito de riesgo de la organización.

- Autoriza decisiones críticas durante incidentes severos, como desconexión de sistemas, activación del plan de continuidad o escalamiento a autoridades externas.
- Garantiza que el IR tenga soporte financiero, estratégico y de gobernanza.

CISO / Responsable de Seguridad de la Información

- Dirige el programa de ciberseguridad y coordina la ejecución del plan de respuesta a incidentes.
- Supervisa los equipos técnicos y establece los criterios de severidad, escalamiento y notificación.
- Informa al AO y a la dirección sobre el estado del incidente.
- Valida que los procedimientos sigan las mejores prácticas del NIST y las políticas internas.

Equipo TI / Administradores de Sistemas

- Ejecutan las acciones técnicas de contención, erradicación y recuperación.
- Aíslan sistemas, aplican parches, realizan análisis forense básico y mantienen la continuidad operativa.
- Documentan las acciones realizadas y protegen la evidencia.
- Colaboran con el SOC cuando corresponde.

SOC / Equipo de Monitoreo (si aplica)

- Detecta anomalías y genera alertas iniciales mediante SIEM o soluciones de monitoreo.
- Identifica indicadores de compromiso y provee información técnica para la toma de decisiones.
- Asiste en el análisis avanzado y en la correlación temporal del incidente.
- Mantiene visibilidad continua del entorno.

Equipo Legal / Cumplimiento

- Evalúa obligaciones regulatorias aplicables (LFPDPPP, LFPC, obligaciones contractuales, etc.).
- Determina si se requiere notificación a clientes, partners o autoridades.
- Asesora sobre riesgos legales derivados del incidente y de la evidencia recolectada.

- Revisa los comunicados oficiales antes de ser emitidos.

Comunicaciones / Relaciones Públicas

- Gestiona mensajes internos y externos para evitar pánico, desinformación o daño reputacional.
- Alinea las comunicaciones con Legal, AO y CISO.
- Garantiza consistencia y precisión en todo mensaje emitido.

Recursos Humanos

- Coordina acciones cuando un incidente involucra empleados, insider threats o procedimientos disciplinarios.
- Asegura la desactivación oportuna de cuentas de empleados desvinculados.
- Participa en la gestión de comunicaciones internas.

Usuarios finales / Personal general

- Reportan de inmediato cualquier actividad sospechosa (correos maliciosos, comportamientos anómalos, accesos inusuales, etc.).
- Cumplen las directrices de TI durante incidentes (desconectar dispositivos, no manipular evidencia, cambiar contraseñas cuando se solicite).
- Participan en capacitaciones de concientización y simulacros.

Proveedores y terceros

- Cumplen con las obligaciones contractuales de seguridad y tiempos de respuesta.
- Notifican de manera oportuna cualquier incidente que pueda afectar a TECNOMARKET.
- Cooperan con TI, CISO y AO durante incidentes que involucren infraestructura externa (ej. Azure).

Actividad / Fase	SOC / TI	CISO	AO	Legal	RRHH	Comunicaciones
Monitoreo y detección	R	C	I	—	—	—
Confirmación de incidente	R	C	I	—	—	—
Activación del Plan de IR	C	A	I	—	—	—
Análisis técnico y forense	R	C	I	—	—	—
Contención	R	C	I	—	—	—
Erradicación	R	C	I	—	—	—
Recuperación	C	R	I	—	—	—
Comunicación interna	I	R	I	—	—	—
Comunicación externa	—	C	A	R	—	R
Decisiones legales / regulatorias	—	C	I	A	—	—
Coordinación en incidentes internos	C	C	I	—	A	—
Post-mortem / Lecciones aprendidas	R	A	I	C	C	C

4. DECLARACIÓN DE LA POLÍTICA

CONFIDENCIALIDAD

La información relacionada con incidentes de seguridad será tratada con estricta confidencialidad y únicamente podrá ser conocida por el personal que tenga una necesidad legítima de saber (*need-to-know*) para el desempeño de sus funciones.

Los detalles técnicos del incidente, su impacto, las vulnerabilidades explotadas, los indicadores de compromiso, la evidencia recopilada y los hallazgos de la investigación estarán restringidos exclusivamente al **Equipo de Respuesta a Incidentes (ERI)** y a aquellos roles ejecutivos cuya participación sea indispensable para la toma de decisiones estratégicas o regulatorias.

El acceso a esta información se encontrará estrictamente controlado mediante mecanismos de gestión de identidades, privilegios mínimos y segregación de funciones.

Queda prohibida la divulgación parcial o total de información relacionada con el incidente a personal no autorizado, terceros, proveedores, clientes o actores externos, salvo cuando sea requerida por ley, auditoría externa, autoridad competente o conforme a acuerdos contractuales específicos previamente establecidos.

El **Oficial Autorizador (AO)** será el responsable de determinar qué información puede ser escalada a la alta dirección —incluidos CISO, CIO, CTO o CEO— manteniendo siempre el principio de mínima exposición y preservando la confidencialidad durante todo el ciclo del incidente, desde su detección hasta su cierre definitivo.

Todo miembro del personal involucrado en la gestión del incidente deberá firmar o haber firmado acuerdos de confidencialidad y será responsable de la correcta protección de los datos sensibles, en especial aquellos relacionados con sistemas críticos, evidencias forenses, datos personales y cualquier información que pueda comprometer la seguridad u operaciones de TECNOMARKET.

INTEGRIDAD

TECNOMARKET garantiza que toda información, sistemas, configuraciones y evidencias digitales mantengan su exactitud, completitud y confiabilidad.
La organización adopta medidas preventivas, detective y correctivas para evitar la alteración no autorizada de datos, software, registros y firmware.

Para ello:

- Solo personal autorizado podrá modificar datos o configuraciones críticas.
- Todo cambio deberá seguir un proceso formal de gestión de cambios, incluyendo aprobación, documentación y validación posterior.
- Los sistemas deberán contar con controles de integridad tales como firmas digitales, hashes, verificadores de integridad y monitoreo continuo para detectar modificaciones no autorizadas.
- Durante un incidente, la organización asegurará la preservación íntegra de logs, evidencias y artefactos recopilados, aplicando cadena de custodia cuando corresponda.
- Tras un incidente, todos los sistemas afectados deberán restaurarse a un estado confiable y verificarse contra las líneas base de seguridad.

El principio de integridad es fundamental para garantizar operaciones confiables, apoyar la investigación de incidentes y evitar que actores maliciosos manipulen o destruyan información.

DISPONIBILIDAD

TECNOMARKET garantiza que los sistemas, servicios y datos esenciales estarán disponibles para los usuarios autorizados cuando sean necesarios para la operación del negocio.
La organización implementará medidas de continuidad operacional como:

- Infraestructura redundante.
- Respaldo periódico de sistemas y datos.
- Pruebas programadas de restauración.
- Controles para prevenir interrupciones causadas por incidentes de ciberseguridad.
- Procedimientos documentados para la recuperación de servicios críticos.

Cualquier interrupción deberá ser gestionada conforme al **Plan de Respuesta a Incidentes** y al **Plan de Continuidad del Negocio**, siguiendo los tiempos y prioridades definidos por la Dirección.

GESTIÓN DE ACCESOS

TECNOMARKET adopta un enfoque basado en **principio de mínimo privilegio (Least Privilege)** y **necesidad de saber (Need-to-Know)** para proteger sus sistemas, datos y servicios.
Solo el personal autorizado tendrá acceso a los recursos necesarios para desempeñar sus funciones.

Controles generales

1. **Autenticación multifactor (MFA):**
   Todos los accesos a sistemas críticos, aplicaciones internas, paneles administrativos, servicios en la nube y Active Directory deben requerir MFA.
2. **Gestión de Identidades y Accesos (IAM):**
   - Se administra mediante **Azure Active Directory** y políticas centralizadas.
   - Se aplican roles basados en privilegios mínimos.
   - Se ejecutan revisiones trimestrales de accesos.
3. **Gestión de Accesos Privilegiados (PAM):**
   Cuentas privilegiadas (Administradores globales, administradores de Azure, administradores de red, etc.) deben:
   - Usar cuentas separadas para tareas administrativas y operativas.
   - Estar bajo supervisión y monitoreo continuo.
   - Rotación de claves y contraseñas cada 45 días o después de un incidente.
4. **Ciclo de vida de cuentas:**
   - Recursos Humanos notifica a TI de **altas, bajas y cambios**.
   - Las cuentas de empleados que salen deben ser **revocadas en menos de 30 minutos** posteriores a la notificación formal.
   - Las cuentas inactivas por más de 90 días serán deshabilitadas automáticamente.
5. **Acceso a datos sensibles:**
   - Los datos clasificados como confidenciales solo son accesibles a roles que lo requieran explícitamente.
   - Accesos extraordinarios requieren aprobación del **AO** o **CISO**.

USO ACEPTABLE DE RECURSOS

TECNOMARKET establece que todos los recursos tecnológicos proporcionados por la organización —incluyendo computadoras, dispositivos móviles, redes, sistemas en la nube y cuentas corporativas— deberán ser utilizados exclusivamente para fines laborales autorizados.

Se consideran pautas de uso aceptable:

1. **Uso profesional:**
   Los recursos tecnológicos deben emplearse únicamente para actividades relacionadas con las funciones del puesto.
2. **Prohibiciones básicas:**
   Queda prohibido instalar software no autorizado, descargar contenido ilegal, acceder a sitios inapropiados o utilizar los sistemas para fines personales que comprometan la seguridad.
3. **Seguridad del dispositivo:**
   Los usuarios deberán mantener los dispositivos actualizados, protegidos con antivirus y configuraciones de seguridad provistas por TI. No se permite desactivar controles de seguridad.
4. **Protección de credenciales:**
   Queda estrictamente prohibido compartir contraseñas, prestar cuentas corporativas o intentar evadir mecanismos de seguridad.
5. **Propiedad y monitoreo:**
   Todos los recursos tecnológicos son propiedad de TECNOMARKET. La organización se reserva el derecho de monitorear su uso conforme a la ley y a las políticas internas.
6. **Reportes obligatorios:**
   Cualquier actividad sospechosa, descarga accidental de malware o uso indebido deberá reportarse de inmediato al área de TI o al Equipo de Respuesta a Incidentes.

GESTIÓN DE INCIDENTES

TECNOMARKET establece que **todo incidente de seguridad** debe ser identificado, reportado, analizado y gestionado siguiendo el *Plan de Respuesta a Incidentes* aprobado por la organización.

La empresa adopta un modelo basado en los lineamientos del **NIST SP 800-61r2/61r3 y CSF 2.0**, mediante el cual:

- **Todo empleado, contratista o tercero** que detecte un evento anómalo debe **reportarlo de inmediato** al equipo de TI o Seguridad, sin importar su aparente gravedad.
- El personal de TI/SOC es responsable de **registrar, clasificar y priorizar** los incidentes según su impacto.
- El **Equipo de Respuesta a Incidentes (ERI)** lidera la contención, mitigación, análisis y recuperación conforme a roles definidos.
- Todos los incidentes deberán quedar **documentados**, incluyendo evidencia, acciones tomadas y lecciones aprendidas.
- TECNOMARKET realizará **ejercicios periódicos** (simulaciones, tabletop, pruebas técnicas) para evaluar y mejorar su capacidad de respuesta.
- La empresa se compromete a mantener **capacidades de recuperación**, incluyendo respaldos, tecnologías de restauración y continuidad operativa.
- La gestión de incidentes deberá cumplir con las **leyes aplicables**, obligaciones contractuales y requisitos de protección de datos personales.

PROTECCIÓN DE DATOS PERSONALES

TECNOMARKET adopta una postura de *privacy by design*, evitando la recopilación de datos personales innecesarios y limitando su uso únicamente a fines operativos legítimos.
La organización cumple con la **Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)**, la **Ley Federal de Protección al Consumidor (LFPC)**, la **normativa aplicable de comercio electrónico**, y otros lineamientos relacionados con la transparencia y el acceso a la información.

Los datos personales que se recaban tanto de empleados, clientes, proveedores o terceros son tratados con responsabilidad, confidencialidad y bajo estrictos controles de seguridad.
TECNOMARKET no vende datos a terceros, no utiliza modelos de *consent-or-pay* y garantiza mecanismos para que los titulares ejerzan sus derechos (ARCO).
Asimismo, solo se implementan cookies estrictamente necesarias, y toda transferencia de datos se realiza bajo medidas de seguridad adecuadas y contratos de confidencialidad.

CONTROL DE CAMBIOS

TECNOMARKET implementa un proceso formal de **Gestión de Cambios (Change Management)** para asegurar que toda modificación a sistemas, aplicaciones, configuraciones, infraestructura y controles de seguridad se realice de manera segura y controlada.

- Todo cambio debe ser **solicitado, evaluado, aprobado y documentado** antes de su ejecución.
- Los cambios que impacten la seguridad, disponibilidad o integridad de los sistemas deberán ser revisados por el **Responsable de Ciberseguridad** y aprobados por el **AO (Authorizing Official)**.
- Los cambios críticos deben pasar por un entorno de **pruebas (staging)** antes de llegar a producción.
- Se mantiene un **registro detallado** de los cambios: fecha, responsable, motivo, validación y resultados.
- Cambios de emergencia deberán documentarse inmediatamente después de su implementación.
- Se utilizan mecanismos de control de versiones y auditoría para asegurar trazabilidad y revertir cambios si es necesario.
- Ningún empleado podrá realizar cambios no autorizados o fuera del proceso establecido.

Este control garantiza que TECNOMARKET mantenga una infraestructura segura, estable y resistente ante errores humanos o configuraciones indebidas.

SEGURIDAD EN LA NUBE

TECNOMARKET reconoce que una porción crítica de su infraestructura, aplicaciones y datos reside en servicios de nube administrados por Microsoft Azure. Por ello, se establecen los siguientes principios y obligaciones:

Modelo de responsabilidad compartida

La seguridad en la nube se rige por un modelo de responsabilidad compartida donde:

- **Azure** es responsable de la seguridad **de** la nube (infraestructura física, hardware, red, hiper-visor, centros de datos, disponibilidad del servicio).
- **TECNOMARKET** es responsable de la seguridad **en** la nube (configuración de identidades, acceso, cifrado, firewalls, políticas, aplicaciones, bases de datos y contenido almacenado).

Cada incidente será evaluado para determinar la responsabilidad, falla, omisión o compromiso tanto de la organización como del proveedor.

Protección de cargas de trabajo en Azure

TECNOMARKET implementa medidas de seguridad específicas para la nube, entre ellas:

- Cifrado en reposo y en tránsito (TLS 1.2+).
- Gestión de identidades y accesos mediante Azure AD e IAM basado en roles (RBAC).
- Controles de acceso condicional y MFA obligatorio.
- Segmentación lógica mediante NSG y firewalls.
- Monitoreo continuo a través de Defender for Cloud.
- Evaluación continua de configuraciones con base en CIS Azure Foundations Benchmark.

Gestión de proveedores

Los servicios en la nube utilizados deben cumplir con estándares regulatorios y de seguridad aplicables a México:

- LFPDPPP
- Ley Federal del Consumidor (cuando aplique a datos de clientes)
- Normativas internacionales relevantes (ISO 27001, SOC 2, etc.)

Además, se mantiene comunicación formal con Azure para:

- Reporte y seguimiento de incidentes.
- Notificaciones de vulnerabilidades o fallos del proveedor.
- Solicitudes de soporte crítico (Sev1 / SevA).

Continuidad y disponibilidad

En caso de incidente que afecte la nube:

- Se activan mecanismos de failover, respaldos y recuperación establecidos por la organización.
- Se priorizan los servicios críticos definidos en el Plan de Continuidad de Negocio (BCP).

TECNOMARKET reconoce la alta dependencia de Azure y se compromete a evaluar en el futuro estrategias de contingencia como multi-nube o entornos híbridos.

Acceso y auditorías

Todos los accesos administrativos a la infraestructura en la nube deberán ser:

- Registrados.
- Monitoreados.
- Limitados bajo el principio de mínimo privilegio.
- Auditados regularmente por TI y el Oficial de Cumplimiento.

TECNOMARKET garantiza la continuidad operativa de sus servicios críticos mediante controles de resiliencia, respaldos periódicos, redundancia en la infraestructura de Azure y procedimientos formales de recuperación.
Se mantienen RTO y RPO alineados al impacto del negocio; estos son revisados regularmente por TI.
La continuidad se activa y coordina junto con el Plan de Respuesta a Incidentes, priorizando la restauración segura de la plataforma de ecommerce, bases de datos y servicios de identidad.
La organización se coordina con Azure para garantizar disponibilidad, soporte y manejo adecuado de incidentes en la nube.

REGULACIONES Y CUMPLIMIENTO

TECNOMARKET se compromete a cumplir con todas las leyes, regulaciones y estándares aplicables en materia de ciberseguridad, protección de datos, privacidad, comercio electrónico y operación digital. La organización establece mecanismos de monitoreo normativo para asegurar que los procesos, controles y actividades de seguridad se mantengan actualizados con los requisitos legales vigentes.

Las operaciones de TECNOMARKET cumplen particularmente con:

- Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)
- Ley Federal de Protección al Consumidor (LFPC)
- Normativa de comercio electrónico y protección de datos aplicable en México
- Estándares y buenas prácticas: NIST CSF 2.0, NIST SP 800-61r3, ISO/IEC 27001, CIS Controls

Toda actualización regulatoria relevante debe ser revisada por el Oficial Autorizador (AO) y el área legal para asegurar su integración oportuna en los procesos internos. El incumplimiento de estas obligaciones podrá derivar en acciones disciplinarias y, en casos graves, consecuencias legales.

RESPONSABILIDAD DE PROVEEDORES

Los proveedores que procesen, almacenen o transmitan información en nombre de TECNOMARKET, así como los que brinden servicios críticos (incluyendo proveedores de nube como Microsoft Azure), deberán cumplir con los estándares de seguridad establecidos por la organización y con las leyes aplicables.

La empresa mantiene acuerdos contractuales que incluyen:

- Cláusulas de confidencialidad y protección de datos
- Requisitos mínimos de seguridad técnica y organizacional
- Procesos de comunicación obligatoria ante incidentes
- Acuerdos de nivel de servicio (SLA) y tiempos de respuesta
- Responsabilidades compartidas en modelos de *cloud security*

TECNOMARKET aplica un modelo de **seguridad de responsabilidad compartida**, en el cual:

- **El proveedor** es responsable de la seguridad de la infraestructura en la nube.
- **TECNOMARKET** es responsable de la configuración segura, gestión de accesos, protección de datos y detección de incidentes dentro de su entorno.

La organización evaluará periódicamente el desempeño y el cumplimiento de sus proveedores mediante auditorías, revisiones de SLA y análisis de riesgo. Cualquier

proveedor que represente un riesgo inaceptable será sujeto a remediación o reemplazo.

5. CUMPLIMIENTO LEGAL

TECNOMARKET se compromete a garantizar que todas las actividades relacionadas con la gestión y respuesta a incidentes de ciberseguridad se realicen en cumplimiento de la legislación y normativas vigentes aplicables en México. Esto incluye, de manera enunciativa pero no limitativa, la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), la Ley Federal de Protección al Consumidor, el Código Penal Federal en materia de delitos informáticos y cualquier regulación sectorial o contractual aplicable.

Durante la gestión de un incidente, la organización debe:

1. **Evaluar si el incidente constituye una brecha de datos personales** y, de ser así, activar los procedimientos establecidos por la LFPDPPP.
2. **Asegurar que la recolección, preservación y análisis de evidencia digital respete requisitos legales**, garantizando integridad, cadena de custodia y admisibilidad.
3. **Notificar a las autoridades competentes o a terceros afectados cuando así lo exija la ley**, dentro de los plazos y formatos correspondientes.
4. **Proteger la privacidad de todas las personas involucradas**, limitando el acceso a datos sensibles únicamente al personal autorizado.
5. **Cumplir los compromisos contractuales de seguridad y confidencialidad con proveedores, socios y clientes**, siguiendo el principio de mínima exposición.
6. **Registrar y documentar todas las acciones** realizadas durante el incidente, manteniendo trazabilidad y consistencia para auditorías internas y externas.

El incumplimiento de las obligaciones legales relacionadas con la respuesta a incidentes puede generar responsabilidades civiles, administrativas o penales; por ello, todo el personal involucrado debe actuar conforme a esta política y con apoyo del área legal cuando sea necesario.

6. CAPACITACIÓN Y CONCIENTIZACIÓN

TECNOMARKET establece un programa continuo de **capacitación y concientización en ciberseguridad**, obligatorio para todo el personal, con el objetivo de fortalecer la resiliencia organizacional frente a incidentes y reducir el riesgo humano asociado a errores operativos, ingeniería social y malas prácticas digitales.

La capacitación incluye tres niveles:

1. **Capacitación General (para todo el personal):**
    - Buenas prácticas de ciberhigiene.
    - Reconocimiento de amenazas comunes (phishing, ransomware, ingeniería social).
    - Manejo responsable de información y dispositivos.
    - Procedimientos de reporte temprano de incidentes.
      Esta formación se apoya en contenidos estructurados de plataformas como *Cisco NetAcad* y otros recursos equivalentes adaptados a perfiles no técnicos.
2. **Capacitación Técnica (personal de TI, Seguridad y Operaciones Críticas):**
    - Gestión de accesos e identidades.
    - Análisis inicial de incidentes.
    - Procedimientos internos de contención y escalamiento.
    - Herramientas de monitoreo, endpoint security y control de vulnerabilidades.
3. **Capacitación Avanzada (equipos responsables de IR):**
    - Simulacros periódicos de respuesta a incidentes.
    - Ejercicios de mesa (table-top exercises).
    - Actualización en amenazas emergentes y técnicas de ataque.
    - Coordinación con proveedores y terceros durante incidentes.

La empresa mantiene un registro verificable de las capacitaciones realizadas, sus responsables y su periodicidad. Todo empleado debe completar la formación

correspondiente a su rol como requisito para el uso de los sistemas corporativos y para la participación en procedimientos relacionados con la Respuesta a Incidentes.